

四类风险到成熟度控制的映射

风险	Foundation	Enhanced	Adaptive
问责	NHI + 委托日志	Agent 一等主体 短凭证	持续认证 风险再认证
最小权限	基础委托边界	细粒度上下文访问	按风险收缩或拒绝
滥用防护	SIEM 审计证据	实时检测异常	实时撤销能力
数据保护	用户与 Agent 身份传播	按任务和资源授权	敏感数据触发升级控制

读表方式：先补可审计的基础控制，再把授权收窄到任务与上下文，最后在风险升高时动态处置。